
MEDICARE CONNECT (PTY) LTD

INFORMATION SECURITY RISK

SUMMARY REPORT

Report to Executive Management

Classification : Confidential

Version : 1.0

Date : June 2025

Compiled by : PV Mohlala
GRC Analyst

Distribution : CEO, IT Manager
Information Officer

1. PURPOSE OF THIS REPORT

This report presents the results of the first formal information security risk assessment conducted at Medicare Connect. It is intended to give management a clear view of where the organization is most exposed and where a limited security budget will deliver the greatest risk reduction.

2. ASSESSMENT AT A GLANCE

Total risks identified : 17

Assets assessed : 12

Risk Exceeding risk appetite : 10

RISK DISTRIBUTION

Critical (20-25) : 5 Risks (29%)

High (12-19) : 10 Risks(59%)

Medium (6-11) : 2 Risks (12%)

Low (1-5) : 0 Risk (0%)

3. THE FIVE RISKS THAT MATTER MOST

1. RSK-001 RANSOMWARE (SCORE 25)

What Happens:

Every patient's medical record becomes inaccessible. Doctors cannot see allergies, medication history or diagnoses during live consultations.

Business Consequence:

Patient safety incident. Practice cannot operate. HPCSA investigation. POPIA availability breach. Potential ransom demand in the millions.

Why it Scores (20) :

Healthcare is the most targeted sector globally for ransomware because downtime is life threatening which increases the likelihood of payment. MediCare has no MFA, no EDR and untested backups.

FIX: MFA + EDR + tested backups

COST: Low (mostly existing licences)

RISK AFTER FIX: 8 (MEDIUM)

2. Rsk-002 Unencrypted Laptops (20)

What happened :

One of the 35 laptops is stolen from a car, at home ,the office or taken by force.

Business Consequence :

Automatic POPIA reportable act. 72
Hours notification to inform the regulator.
Every affected patient must be notified individually. Possible fines estimated at R10 Million in case of a breach.

Why this is the easiest win :

Bitlocker is already included in the Windows licence the company owns.
Enabling it costs nothing but IT time and reduces this risk from 20 to 4.

FIX : Enable bitlocker on all devices

Cost: R0 (already licensed)

Risk after Fix : Fix (4)

3. Risk- 003 Phishing (Score 20)

What happens :

A staff member clicks on a Phishing link and enters their Microsoft 365 password on a fake login page.

Business Consequence :

Attacker reads all patient referrals, test results and medical correspondence in the mailbox Uses the account to phish other staff and patients from a trusted address.

Why It scores 20 :

Phishing emails reach staff inboxes weekly. Without MFA a stolen password is a complete account access.

Fix : MFA + awareness training

Cost : R0 for MFA , low for training

Risk after Fix : 6 (Medium)

4. Risk -004 No Information officer (20)

What happens :

Nothing visible until a patient complains to the information regulator or a breach occurs

Business Consequence :

POPIA section 55 requires that every responsible party have a registered Information Officer. Non compliance is a statutory failure that directors are personally liable for. It also signals to a regulator that no other POPIA obligations are met.

Why this is urgent :

This is a paperwork fix that takes one day and removes a criminal liability exposure for the directors.

Fix : appoint and register officer

Cost : R0

Risk after Fix : 3 (Low)

5. Risk- 005 No Incident Response (20)

What happens :

A breach occurs and nobody knows who to call, what to record , who decides or when to notify the regulator.

Business Consequence :

The 72 hour POPIA notification window is missed. A recoverable incident becomes a regulatory enforcement matter. Evidence is destroyed. Insurance claims denied.

Why this amplifies every other risk :

Every other risk on this register becomes worse if the response is slow or undocumented. This control reduces the impact of all 16 other risks simultaneously.

Fix : Write and test IR plan

Cost : Internal time only

Risk after Fix : 6 (Medium)

4. South African Context Risk

This assessment identified four risks specific to operating in South Africa that generic security frameworks typically overlook. :

Risk-008 Load Shedding (Score 15)

Stage 6 load shedding causes repeated abrupt server shutdowns. This is the highest likelihood risk on the register at score 5. It is almost certain to occur.

Risk-013 Sim Swap Fraud (Score 12)

South Africa has one of the highest SIM swap fraud rates globally. Any control relying on SMS OTP is compromised.

Risk-017 Fibre Cable Theft (Score 9)

Infrastructure theft is a recognised availability risk in Gauteng affecting telehealth service continuity.

Risk-014 Physical File Theft (Score 12)

Legacy paper records remain a common exposure in SA private practices that have partially digitised.

5. Recommended Priority Order

The following sequence delivers maximum risk reduction for minimum cost :

Month 1: - Zero Cost Quick Wins

Reduces total risk exposure by a further 34%

- Enable MFA on Microsoft 365 (Risk -003)
- Enable bitlock encryption (Risk -002)
- Appoint Information officer (Risk -004)
- Combined cost : R0
- Risk score reduction : 60 points

Month 2 - Core protection

Reduces total risk exposure by a further 22%

- Implement tested backup (Risk -001)
- Write incident response plan (Risk -005)
- Fix offboarding price (Risk -013)
- Replace SMS OPT (Risk -013)
- Combined cost :Low moderate
- Risk score reduction : 45 Points

Month 3 - Monitoring and Awareness

- Access logging and review (Risk -006)
- Security Awareness training (Risk -003)
- UPS and generator (Risk -008)
- Physical access control (Risk -014)
- Email DLP (Risk-010)

Month 4 -Party and testing

- Vendor assessment (Risk-007)
- Penetration test of portal (Risk -015)
- LTE failover Connection (Risk -017)

6.Key Message for Management

Three of the five Critical risks on this register can be eliminated in month 1 at zero licensing cost using tools Medicare Connect already owns. MFA , Bitlocker encryption and appointing Information officer require IT time and a management decision. Nothing more.

Those three actions alone reduce the organization's most severe exposures from critical to low and remove the direct personal liability currently carried by the directors under POPIA section 55.

Doing nothing is the most expensive option available.

7.Next Steps

1. Management review and approval of this risk register.
2. Risk owners to formally accept assigned risks
3. Month 1 treatment actions to commence immediately
4. Progress review in 30 days
5. Full risk register review quarterly

Document Control

Compiled by: : Patrick Vusumuzi Mohlala - GRC Analyst
Date : June 201
Version : 1.0
Status : Final - For Management review

Next Review : September 2025